

Peretto

marcos
Luciano

PDI — ATIVIDADE 04 · REGISTRO DE ENTREGA

Conformidade **LGPD** em Eventos e Dados (anonimizacao, consentimento, esquecimento)

Autor: PDI Marcos Luciano - marcosluciano.rodrigues@v4company.com

Unidade: FV Marketing / V4 Company — Automação & Infraestrutura

Módulo: 05 · Sistemas Distribuídos, Mensageria e Eventos

Data: Agosto 2026

Status: **NÃO PUBLICADO** · Desenvolvido / Homologação pendente

Versão: 1.0

consent / retention / anonymize

1. Contexto

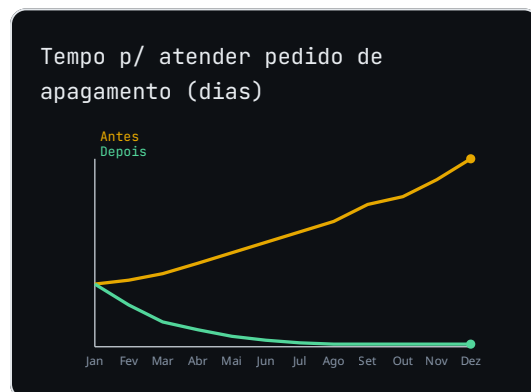
A FV roda dados de clientes em **vários serviços**: o evento `lead.criado` viaja por Vendas, Marketing, Enriquecimento e Analytics. A **LGPD** exige que dado pessoal só circule com **base legal** (consentimento), seja guardado pelo **tempo mínimo** e possa ser **anonimizado ou apagado**. Num sistema distribuído, o dado pessoal se espalha — e o risco também.

ANALOGIA DO BILHETE COM CPF

Você passa um bilhete com seu CPF para o atendente, que o repassa ao caixa, que o cola num quadro, que o manda ao RH. Se um desses lugares vazar, seu CPF está na rua e ninguém sabe de quem foi a culpa. A LGPD em dados distribuídos é: **só repasse o CPF se o cliente autorizou**, manche o bilhete ao sair do setor (anonimize), e destrua o original quando o prazo vencer (retenção). Cada sala precisa de regra.

2. Diagnóstico

Hoje o `lead.criado` carrega CPF, e-mail e telefone em **texto puro** por todos os tópicos. Não há flag de consentimento, nem prazo de retenção, nem criptografia em repouso. Um auditor da ANPD pede 'apague o João' e ninguém acha em qual serviço o dado parou. Multa e imagem em risco.

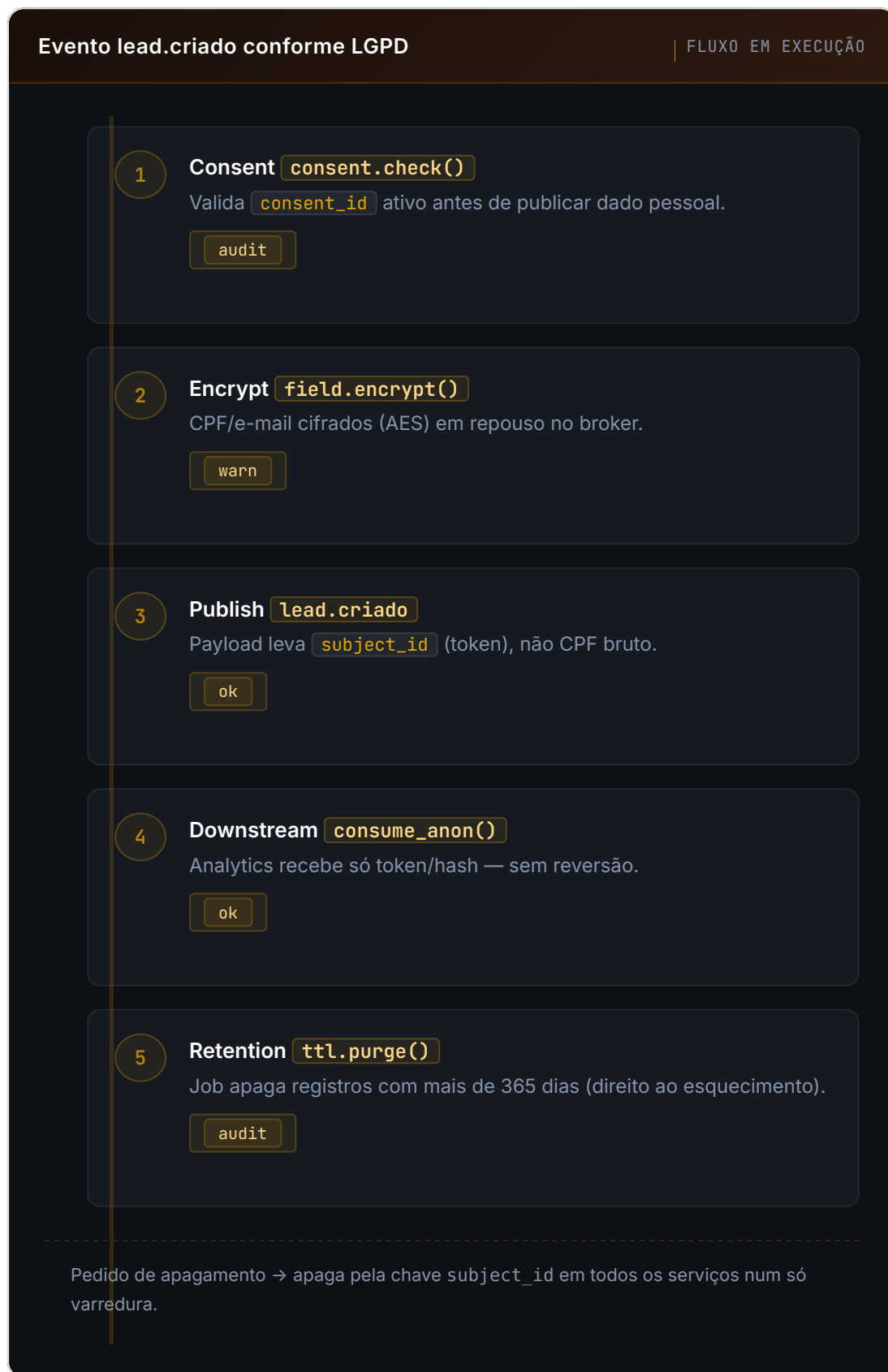


Raiz do problema: o dado pessoal é replicado sem **consentimento explícito** nem **marcação de ciclo de vida**. Não há rastro de onde o dado vive, então o direito ao esquecimento é inviável.

3. Solução

Tratar LGPD como **parte do pipeline de eventos**. Regras: (1) **consentimento** via flag `consent_id` no payload — só publica dado pessoal se houver base legal; (2) **criptografia** em repouso (campo sensível cifrado) e em trânsito (TLS); (3) **anonimizar** ao sair do contexto primário (hash irreversível ou tokenização); (4) **retenção** com TTL — job apaga após X dias. O payload leva `subject_id` em vez de CPF nas etapas downstream.

4. Como funciona (pipeline)



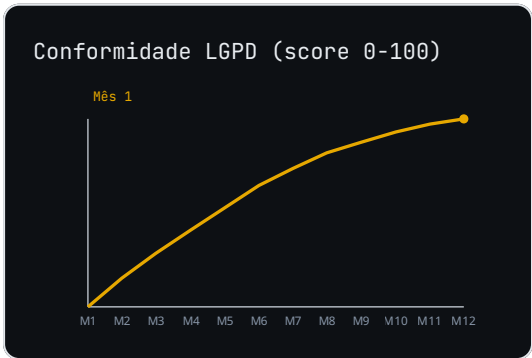
5. Antes vs Depois

CENÁRIO	ANTES (TEXTO PURO)	DEPOIS (CONFORME LGPD)
Consentimento	Ausente	Flag consent_id obrigatória
CPF em trânsito	Visível	Cifrado + tokenizado
Pedido de apagamento	90 dias	< 1 dia (subject_id)
Retenção	Infinita	TTL 365d

6. Entregas

- **Schema** `lead_event.avsc`: campos sensíveis marcados `pii:true`.
- **Lib** `lgpd_crypto.py`: encrypt/decrypt AES + tokenize.
- **Job** `retention_purge.py`: varre e apaga por `subject_id` / TTL.
- **Doc** `mapa-dados.md`: onde cada PII vive e seu prazo.

7. Métricas



Meta: 100% dos eventos com consentimento, zero PII em texto puro em trânsito e pedido de apagamento resolvido em < 24h.

8. Status final

NÃO PUBLICADO — Desenvolvido e em homologação. Aguarda revisão antes de produção.